

Pretty Good Privacy (PGP)

Pretty Good Privacy (PGP)

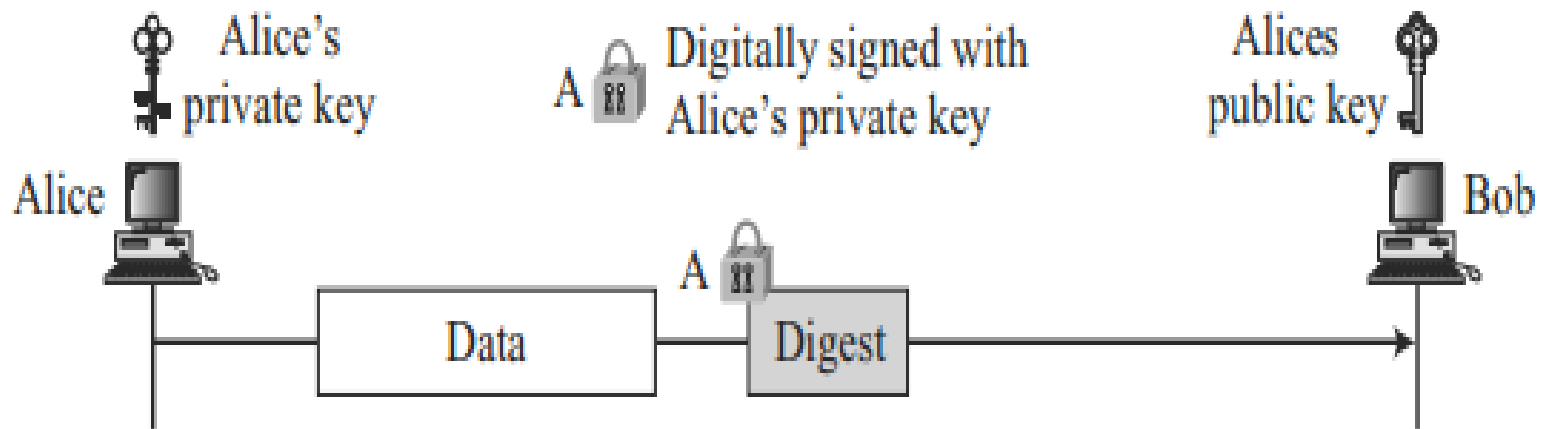
- PGP was invented by **Phil Zimmermann** to provide e-mail with privacy, integrity, and authentication.
- PGP can be used to create a secure e-mail message or to store a file securely for future retrieval.

Pretty Good Privacy (PGP)

- PGP consists of the following services:
 - Integrity
 - Authentication
 - Confidentiality
 - Compression
 - Code Conversion
 - Segmentation

Message Integrity

- Sender creates a digest of the message and signs it with his private key.



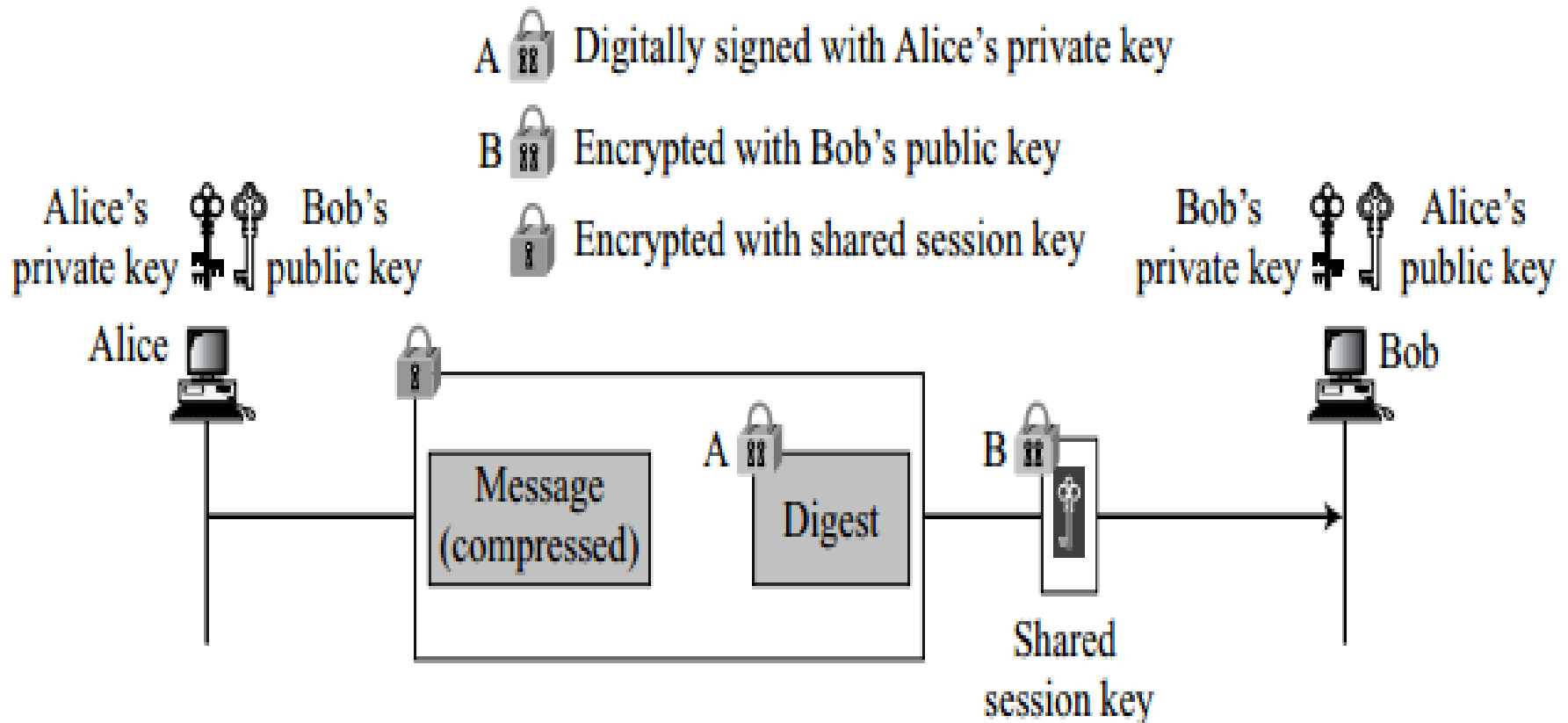
Confidentiality

- It is provided by encrypting messages to be transmitted or to be stored locally as files.
- In both cases, the user has a choice of CAST-128, IDEA or 3DES in 64 bit cipher feedback (CFB) mode.

Confidentiality with One-Time Session Key

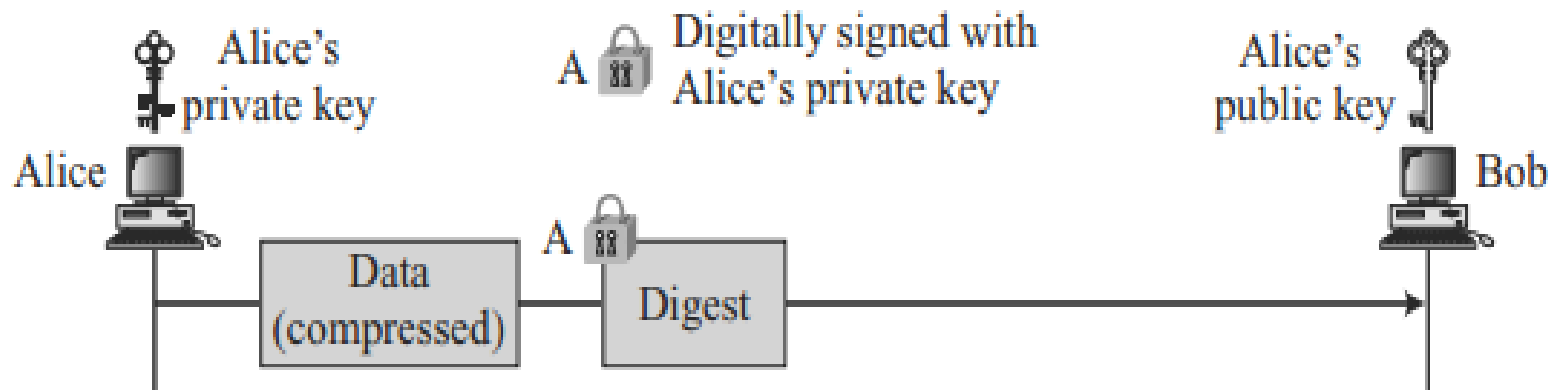
- The confidentiality in an e-mail system can be achieved using conventional encryption with a one-time session key.
- The sender can create a session key
 - use the session key to encrypt the message and the digest and send the key itself with the message.
 - to protect the session key, sender encrypts it with receiver's public key

Confidentiality with One-Time Session Key



Compression

- A further improvement is to compress the message to make the packet more compact



Code Conversion

- Most e-mail systems allow the message to consist of only ASCII characters.
- To translate other characters not in the ASCII set, PGP uses **Radix-64** conversion.

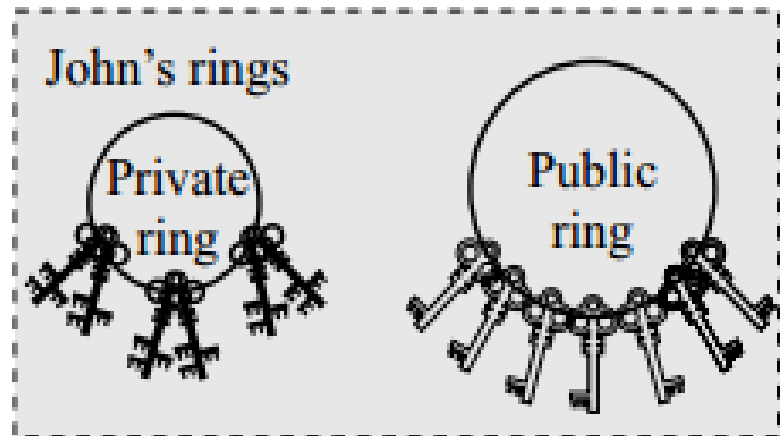
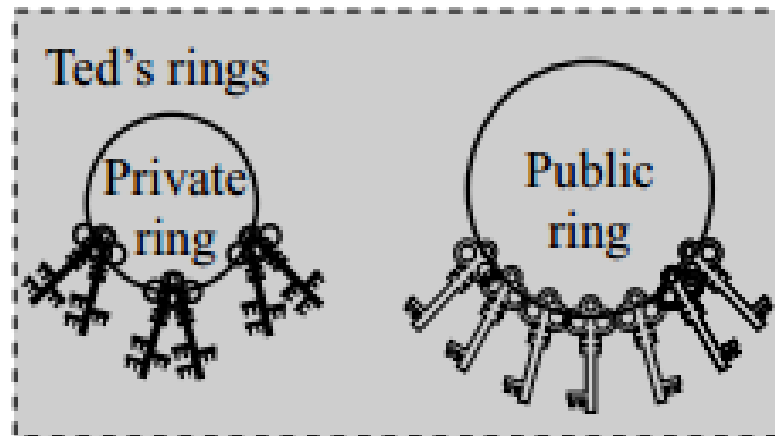
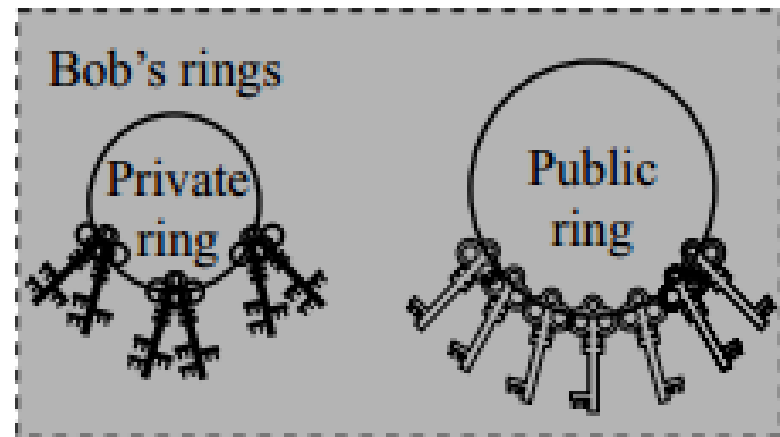
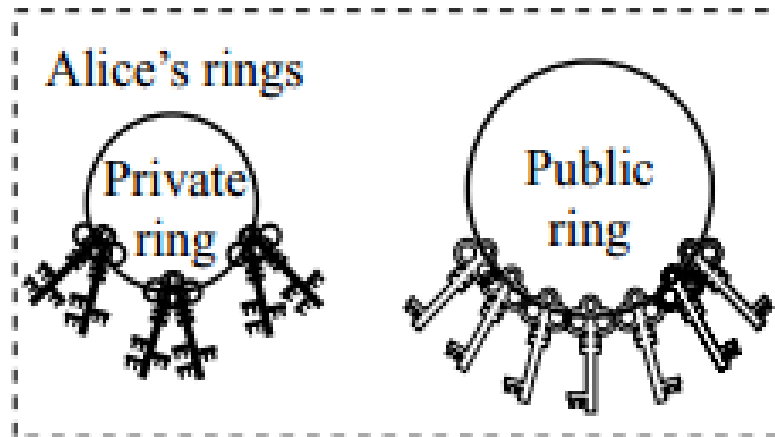
Segmentation

- E-mail facilities are often restricted to a maximum message length (50,000 octets).
- Any message longer than that must be broken up into smaller segments, each of which is mailed separately.
- PGP automatically subdivides a message that is too large into segments that are small enough to sent via e-mail.
- PGP allows segmentation of the message after it has been converted to Radix-64
 - Helps each transmitted unit of uniform size as allowed by the underlying e-mail protocol

Key Rings in PGP

- Key Rings are essential to send messages to many people (User may wish to use a different key pair for each group).
- PGP needs two rings:
 - a ring of public keys, with a key belonging to each person with whom Alice needs to correspond
 - a ring of private/public keys

Key rings in PGP



Sending and Receiving messages using Key rings in PGP

- Alice needs to send a message to another person in the community.
 - She uses her private key to sign the digest.
 - She uses the receiver's public key to encrypt a newly created session key.
 - She encrypts the message and signed digest with the session key created.
- Alice receives a message from another person in the community.
 - She uses her private key to decrypt the session key.
 - She uses the session key to decrypt the message and digest.
 - She uses her public key to verify the digest.

PGP Algorithms

- The following algorithms are used in PGP
 - Public-Key Algorithms
 - Symmetric-Key Algorithms
 - Hash Algorithms
 - Compression Algorithms

PGP Algorithms

<i>ID</i>	<i>Description</i>
1	RSA (encryption or signing)
2	RSA (for encryption only)
3	RSA (for signing only)
16	ElGamal (encryption only)
17	DSS
18	Reserved for elliptic curve
19	Reserved for ECDSA
20	ElGamal (for encryption or signing)
21	Reserved for Diffie-Hellman
100–110	Private algorithms

Public-key algorithms

<i>ID</i>	<i>Description</i>
0	No Encryption
1	IDEA
2	Triple DES
3	CAST-128
4	Blowfish
5	SAFER-SK128
6	Reserved for DES/SK
7	Reserved for AES-128
8	Reserved for AES-192
9	Reserved for AES-256
100–110	Private algorithms

Symmetric-key algorithms

PGP Algorithms

<i>ID</i>	<i>Description</i>
1	MD5
2	SHA-1
3	RIPE-MD/160
4	Reserved for double-width SHA
5	MD2
6	TIGER/192
7	Reserved for HAVAL
100–110	Private algorithms

Hash Algorithms

<i>ID</i>	<i>Description</i>
0	Uncompressed
1	ZIP
2	ZLIP
100–110	Private methods

Compression methods

PGP Certificates

- PGP recognizes two different certificate formats:
 - PGP certificates (more commonly referred to simply as PGP keys)
 - X.509 certificates

X.509 certificate format of PGP

- An X.509 certificate is a collection of a standard set of fields containing information about a user or device and their corresponding public key.
- All X.509 certificates have the following data:
 - X.509 version number
 - certificate holder's public key
 - serial number of the certificate
 - certificate holder's unique identifier

- An X.509 certificate is issued by a CA with appropriate procedure.
- In X.509, there is a single path from the fully trusted authority to any certificate
 - As it depends on the hierarchical structure of the trust.

PGP Certificates

- In PGP, there is no need for CAs
 - anyone in the ring can sign a certificate for anyone else in the ring.
 - In PGP, the issuer of a certificate is usually called an **introducer**.
- A PGP certificate includes:
 - PGP version number
 - certificate holder's public key
 - certificate holder's information
 - digital signature of the certificate owner (***self-signature***)
 - certificate's validity period
 - preferred symmetric encryption algorithm for the key

Trust models

- In PGP, the issuer of a certificate is usually called an **introducer**.
- PGP allows different levels of trust for an introducer
 - None
 - partial
 - full
- There can be multiple paths in the line of trust from a fully or partially trusted authority to a certificate.
- There is no mechanism in PGP to determine how to make a decision about the trustworthiness of the introducer
 - it is up to the user to make this decision.

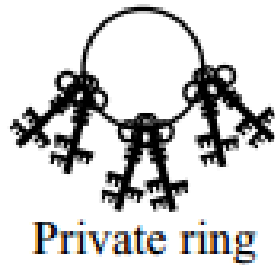
Levels of trust in PGP

- The highest level of trust in a key, **implicit trust**, is trust in a user's own key pair.
- Any keys signed by the user's implicitly trusted key are valid.
- To define another's key as a trusted introducer:
 - Start with a valid key, one that is either
 - signed by the user or
 - signed by another trusted introducer
 - Set the level of trust you feel the key's owner is entitled.

Key Ring Tables

- Each user keeps track of two key rings: one private-key ring and one public key ring.
- PGP defines a structure for each of these key rings in the form of a table.

Private Key Ring Table



User ID	Key ID	Public key	Encrypted private key	Timestamp
⋮	⋮	⋮	⋮	⋮

- The **user ID** is usually the e-mail address of the user.
- Key ID** column uniquely defines a public key among the user's public keys
- Public Key** column lists the public key belonging to a particular private key/public key pair.
- Encrypted Private Key** column shows the encrypted value of the private key
- Timestamp** column holds the date and time of the key pair creation.

Private Key Ring Table

<i>User ID</i>	<i>Key ID</i>	<i>Public Key</i>	<i>Encrypted Private Key</i>	<i>Timestamp</i>
alice@anet.net	AB13...45	AB13...45...59	32452398...23	031505-16:23
alice@some.com	FA23...12	FA23...12...22	564A4923...23	031504-08:11

Public Key Ring Table



User ID	Key ID	Public key	Producer trust	Certificate(s)	Certificate trust(s)	Key Legitimacy	Timestamp
⋮	⋮	⋮	⋮	⋮	⋮	⋮	⋮

- The **user ID** is usually the e-mail address of the entity.
- The **key ID** is the first (least significant) 64 bits of the public key.
- Producer Trust** column defines the producer level of trust
- Certificate** column holds the certificate or certificates signed by other entities for this entity.
- Key Legitimacy** is calculated by PGP based on the value of the certificate trust and the predefined weight for each certificate trust.

Example

- Starting table

<i>User ID</i>	<i>Key ID</i>	<i>Public key</i>	<i>Prod. trust</i>	<i>Certificate</i>	<i>Cert. trust</i>	<i>Key legit.</i>	<i>Time-stamp</i>
Alice...	AB...	AB.....	F			F	

Alice adds Bob to the table. Alice fully trusts Bob

After Bob is added to the table

<i>User ID</i>	<i>Key ID</i>	<i>Public key</i>	<i>Prod. trust</i>	<i>Certificate</i>	<i>Cert. trust</i>	<i>Key legit.</i>	<i>Time-stamp</i>
Alice...	AB...	AB.....	F			F	
Bob...	12...	12.....	F			F	

- Alice adds Ted to the table. Ted is fully trusted.
- After Ted is added to the table

<i>User ID</i>	<i>Key ID</i>	<i>Public key</i>	<i>Prod. trust</i>	<i>Certificate</i>	<i>Cert. trust</i>	<i>Key legit.</i>	<i>Time-stamp</i>
Alice...	AB...	AB.....	F			F	
Bob...	12...	12.....	F			F	
Ted...	48...	48.....	F	Bob's	F	F	

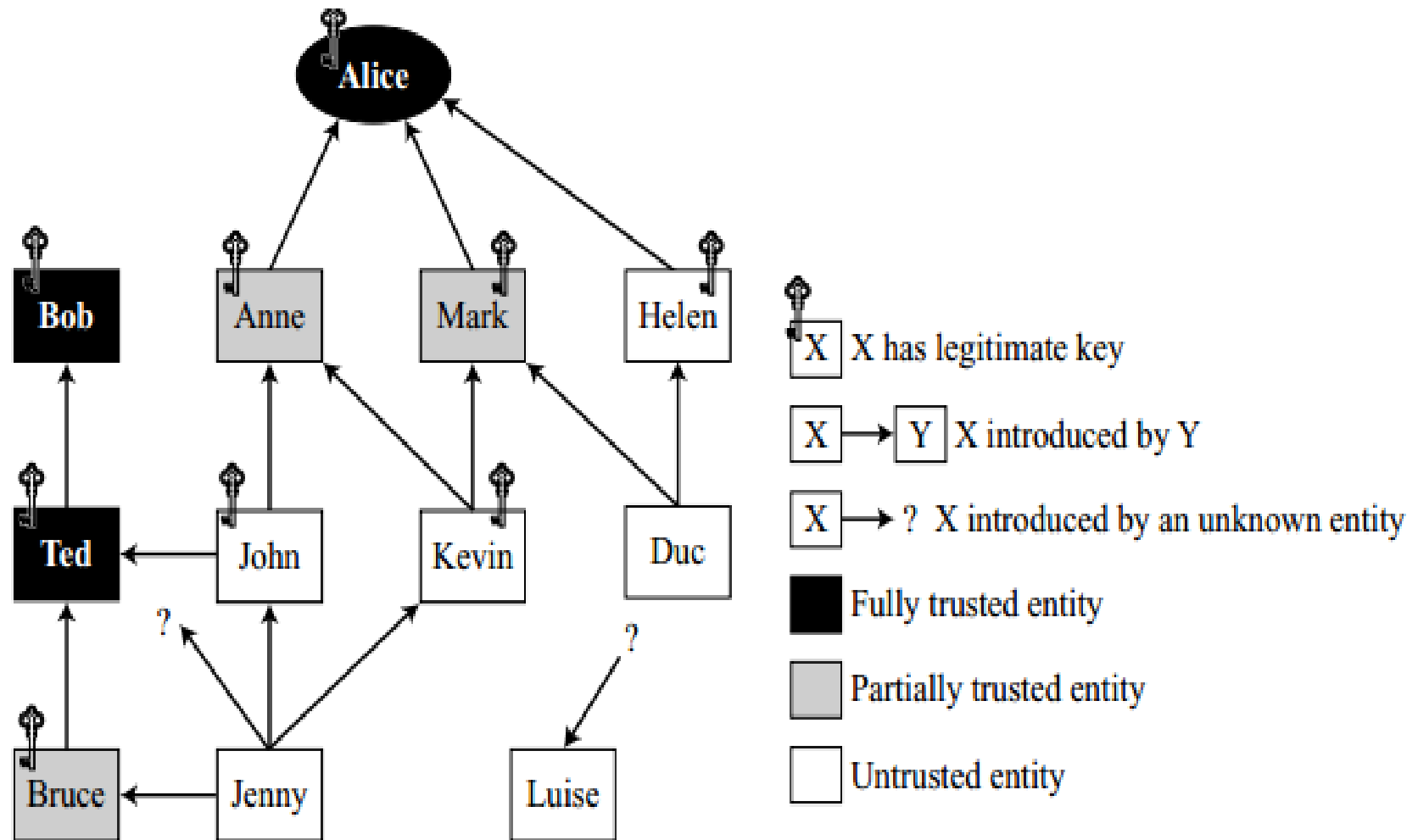
- Alice adds Anne to the list. Alice partially trusts Anne, but Bob, who is fully trusted, sends a certificate for Anne.
- After Anne is added to the table

<i>User ID</i>	<i>Key ID</i>	<i>Public key</i>	<i>Prod. trust</i>	<i>Certificate</i>	<i>Cert. trust</i>	<i>Key legit.</i>	<i>Time-stamp</i>
Alice...	AB...	AB.....	F			F	
Bob...	12...	12.....	F			F	
Ted...	48...	48.....	F	Bob's	F	F	
Anne...	71...	71.....	P	Bob's	F	F	

- Anne introduces John, who is not trusted by Alice. After John is added to the table

<i>User ID</i>	<i>Key ID</i>	<i>Public key</i>	<i>Prod. Trust</i>	<i>Certificate</i>	<i>Cert. trust</i>	<i>Key legit.</i>	<i>Time-stamp</i>
Alice...	AB...	AB.....	F			F	
Bob...	12...	12.....	F			F	
Ted...	48...	48.....	F	Bob's	F	F	
Anne...	71...	71.....	P	Bob's	F	F	
John...	31...	31.....	N	Anne's	P	P	

Trust model



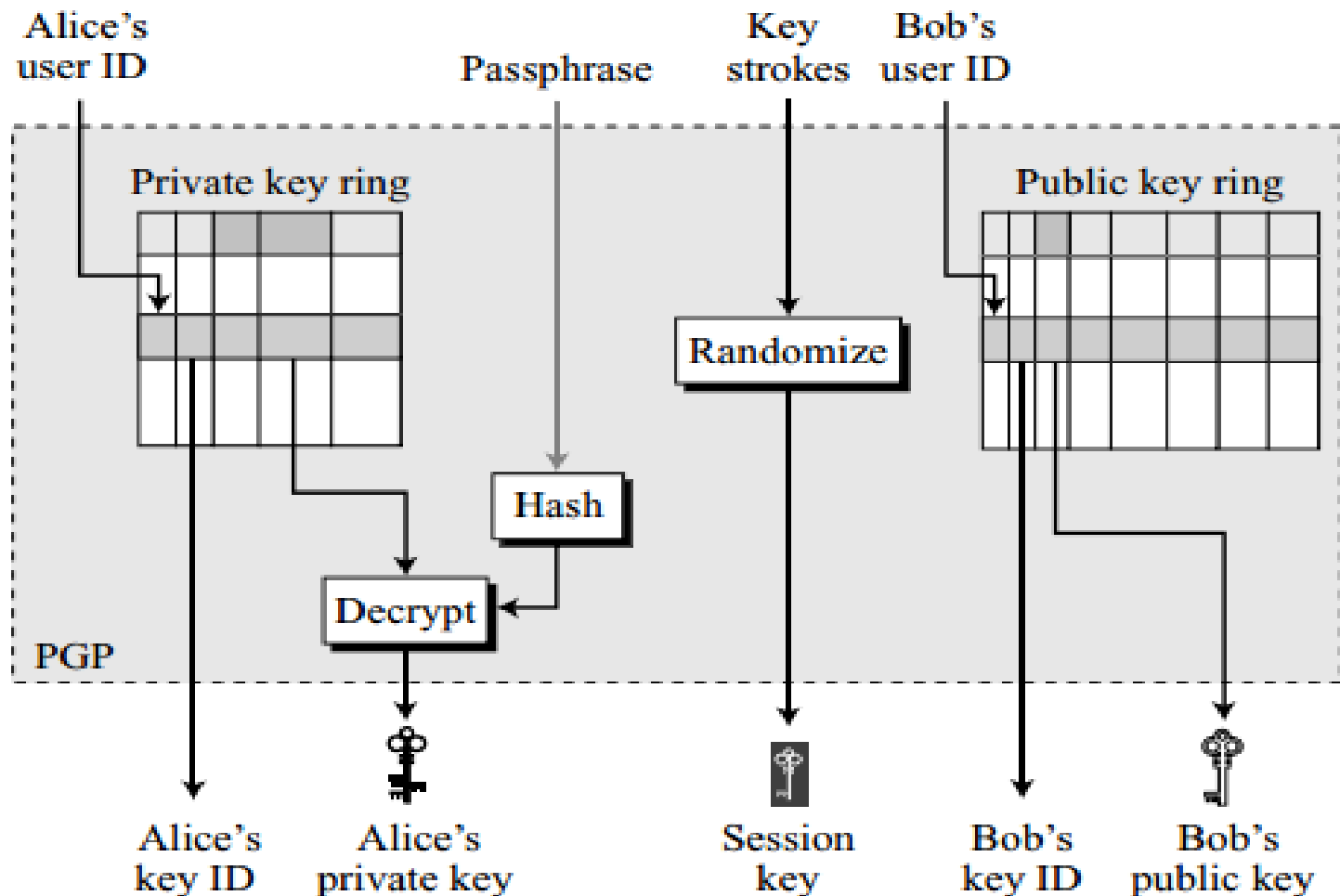
Key Revocation

- An entity can revoke his or her public key from the ring if the owner of the key feels that the key is compromised
- To revoke a key, the owner can send a revocation certificate signed by herself.
- The revocation certificate must be signed by the old key
 - Should be disseminated to all the people in the ring that use that public key.

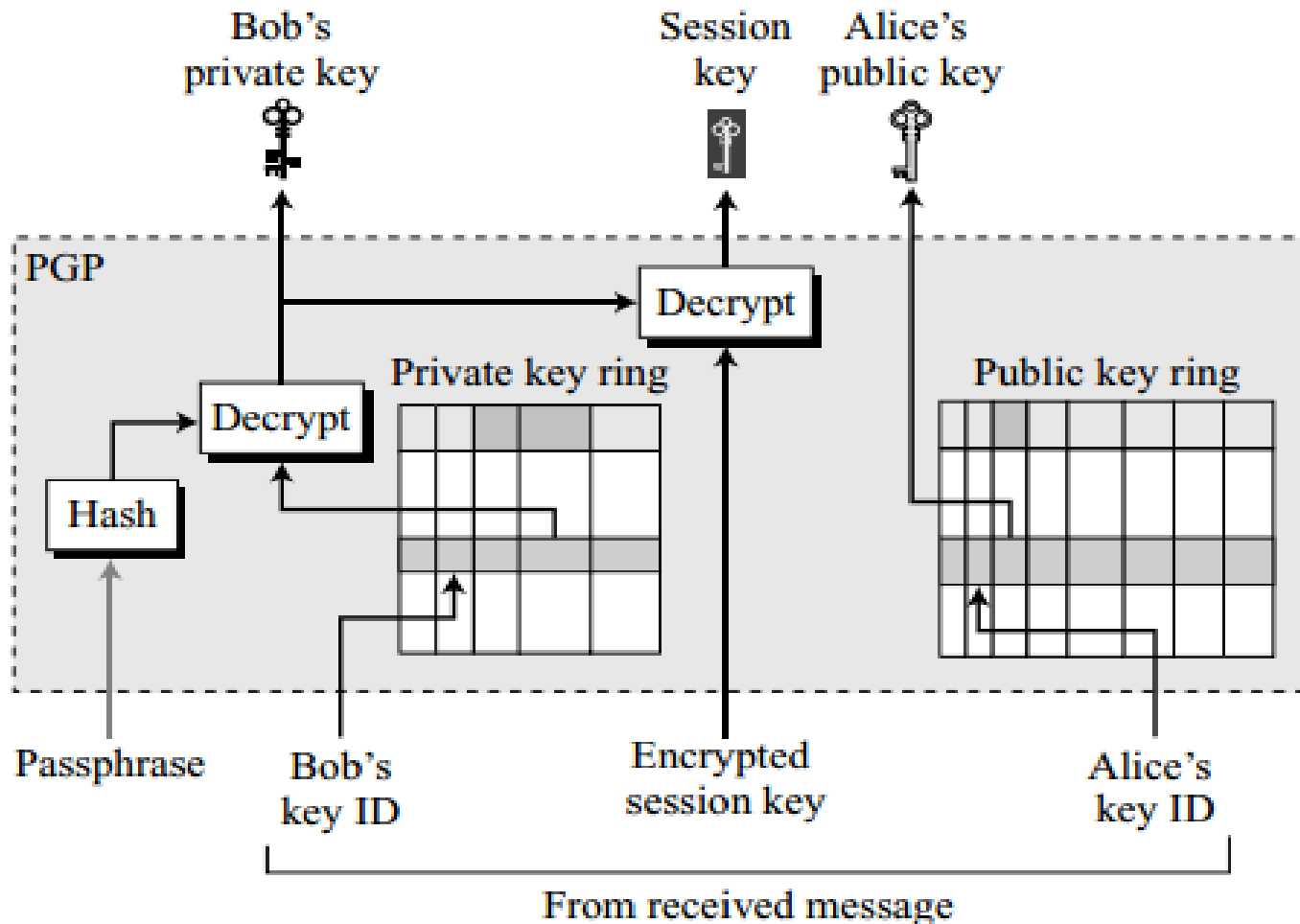
Extracting Information from Rings

- Some information needed for sending and receiving a message can be extracted from these two key rings.
- At Sender Site:
 - five pieces of information needed by the sender: the key ID of the public key she is using, her private key, the session key, Bob's publickey ID, and Bob's public key.

Extracting information at the sender site

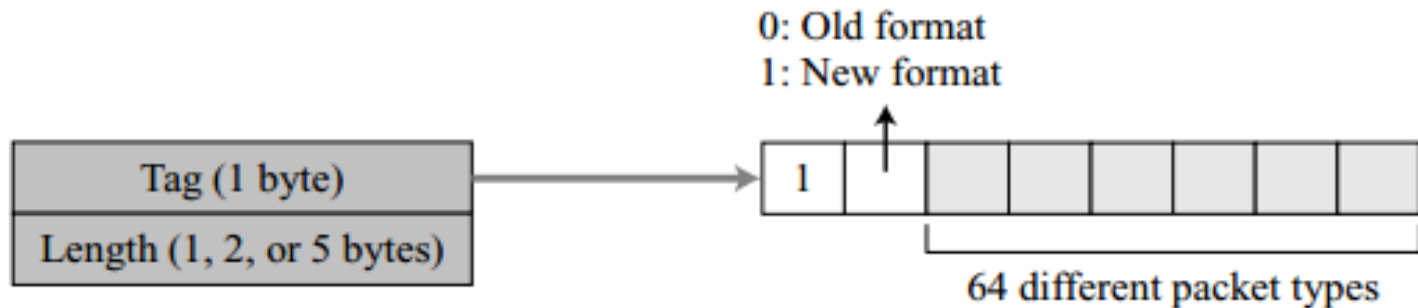


Extracting information at the receiver site



PGP Packets

- A message in PGP consists of one or more packets.
- PGP has a generic header that applies to every packet, **has only two fields**



Format of packet header

PGP Packets

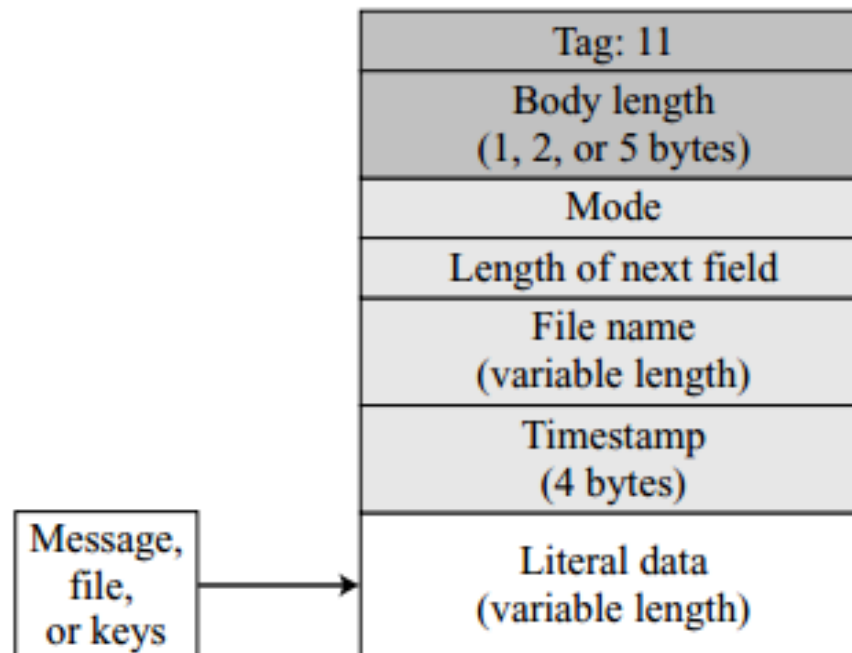
- The **length field** defines the length of the entire packet in bytes.
 - The size of this field is variable; it can be 1, 2, or 5 bytes.
 - The receiver can determine the number of bytes of the length field by looking at the value of the byte immediately following the tag field.

Some commonly used packet types

<i>Value</i>	<i>Packet type</i>
1	Session key packet encrypted using a public key
2	Signature packet
5	Private-key packet
6	Public-key packet
8	Compressed data packet
9	Data packet encrypted with a secret key
11	Literal data packet
13	User ID packet

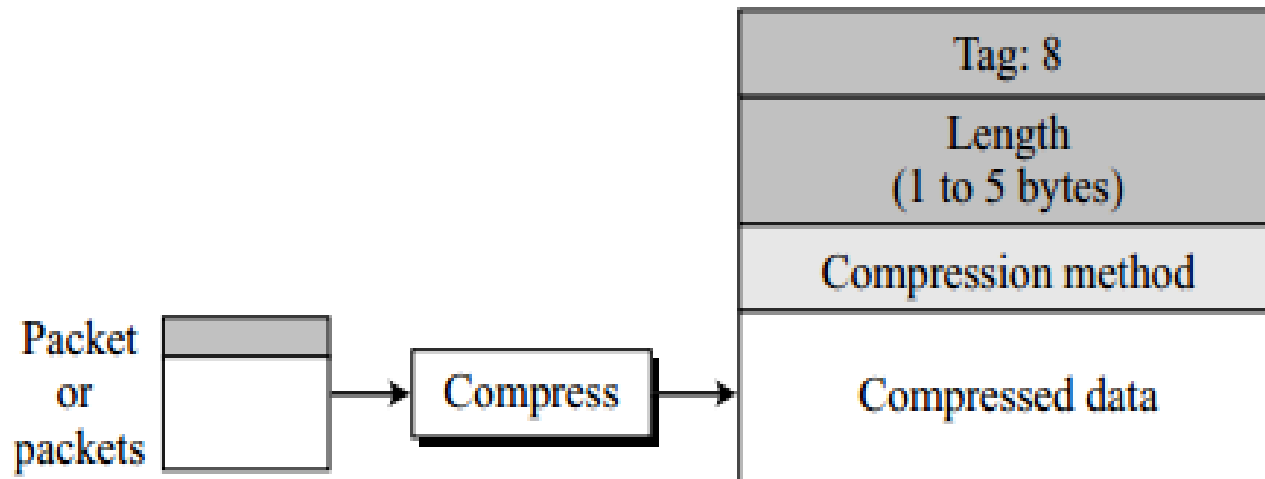
Literal Data Packet

- It is the packet that carries or holds the actual data that is being transmitted or stored.



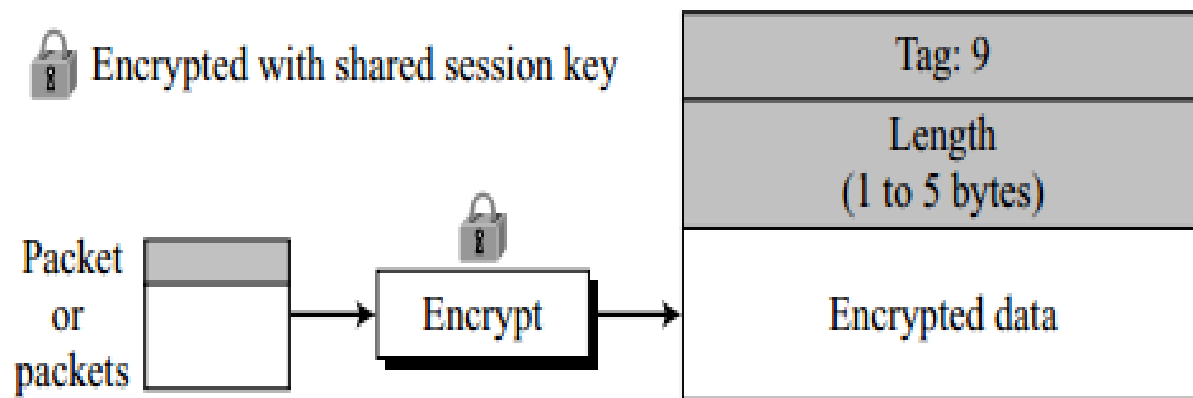
Compressed Data Packet

- This packet carries compressed data packets
- The data in this field can be one packet or the concatenation of two or more packets.



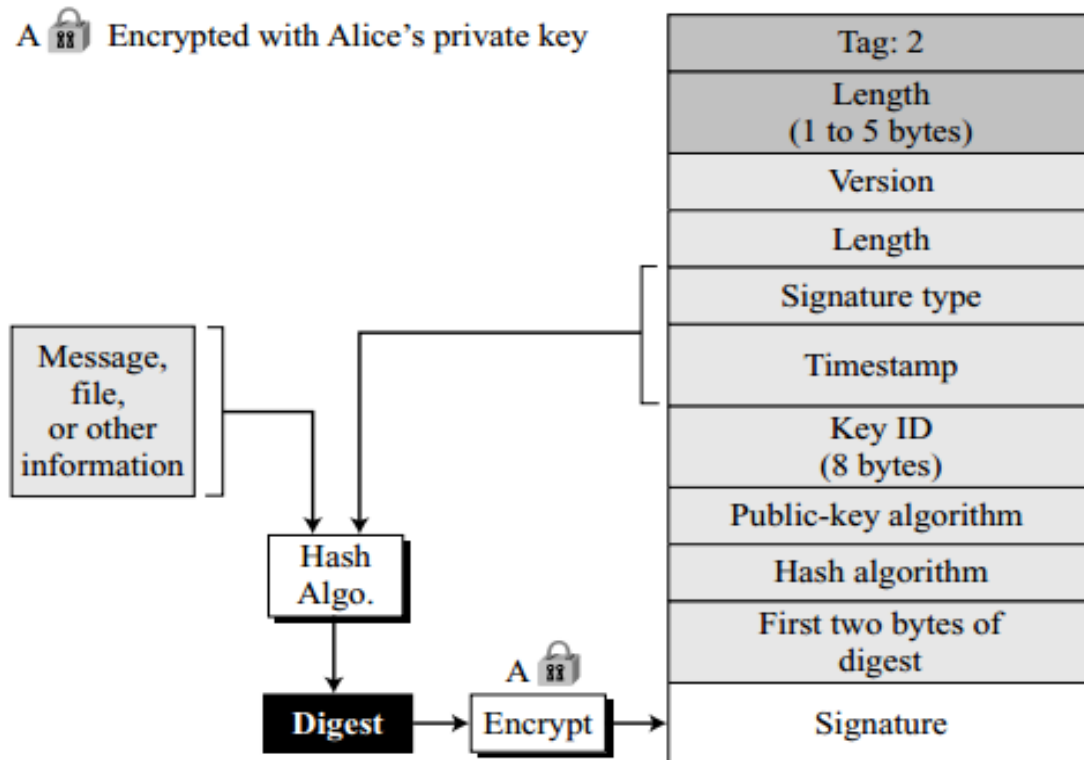
Encrypted data packet

- It carries data from one packet or a combination of packets that have been encrypted using a conventional symmetric key algorithm.



Signature Packet

- A signature packet protects the integrity of the data.

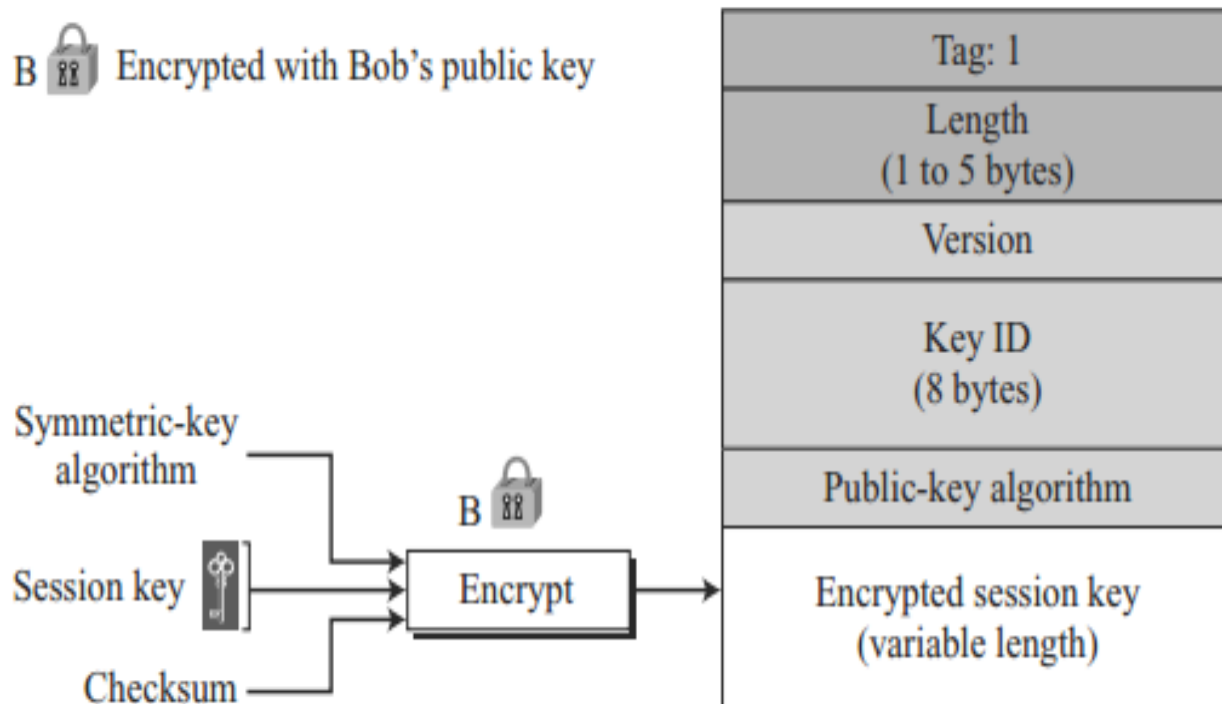


- Some signature values:

<i>Value</i>	<i>Signature</i>
0x00	Signature of a binary document (message or file).
0x01	Signature of a text document (message or file).
0x10	Generic certificate of a user ID and public-key packet. The signer does not make any particular assertion about the owner of the key.
0x11	Personal certificate of a user ID and public-key packet. No verification is done on the owner of the key.
0x12	Casual certificate of a User ID and public-key packet. Some casual verification done on the owner of the key.
0x13	Positive certificate of a user ID and public-key packet. Substantial verification done.
0x30	Certificate revocation signature. This removes an earlier certificate (0x10 through 0x13).

Session-key packet

- It is used to send the session key encrypted with the receiver public key.



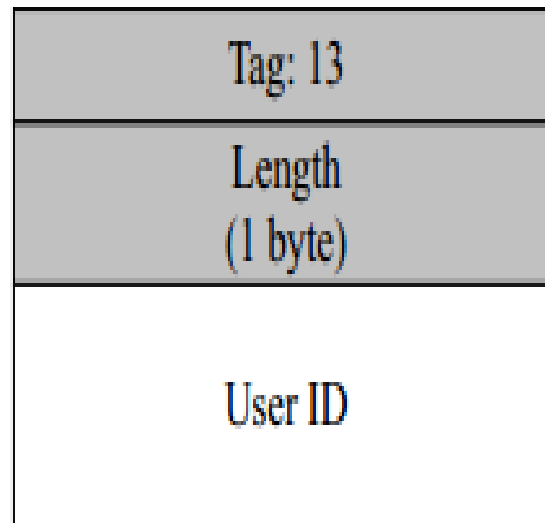
Public-Key Packet

- It contains the public key of the sender

Tag: 6
Length (1 to 5 bytes)
Version
Key ID (8 bytes)
Public-key algorithm
Public key

User ID Packet

- This packet identifies a user.
 - can normally associate the user ID contents with a public key of the sender.



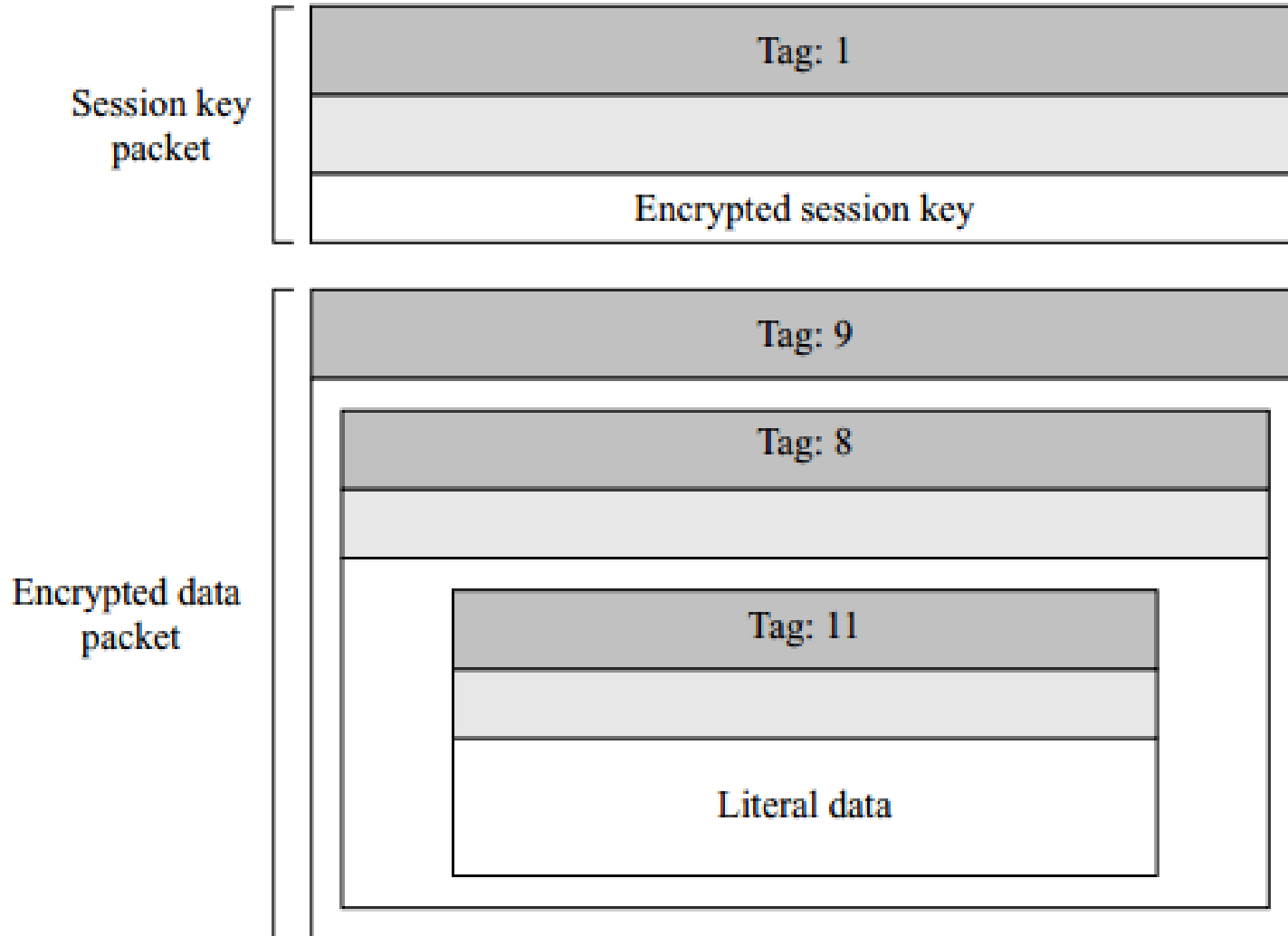
PGP Messages

- A message in PGP is a combination of sequenced and/or nested packets.
- Various types of PGP messages are:
 - Encrypted message
 - Signed message
 - Certificate message

Encrypted Message

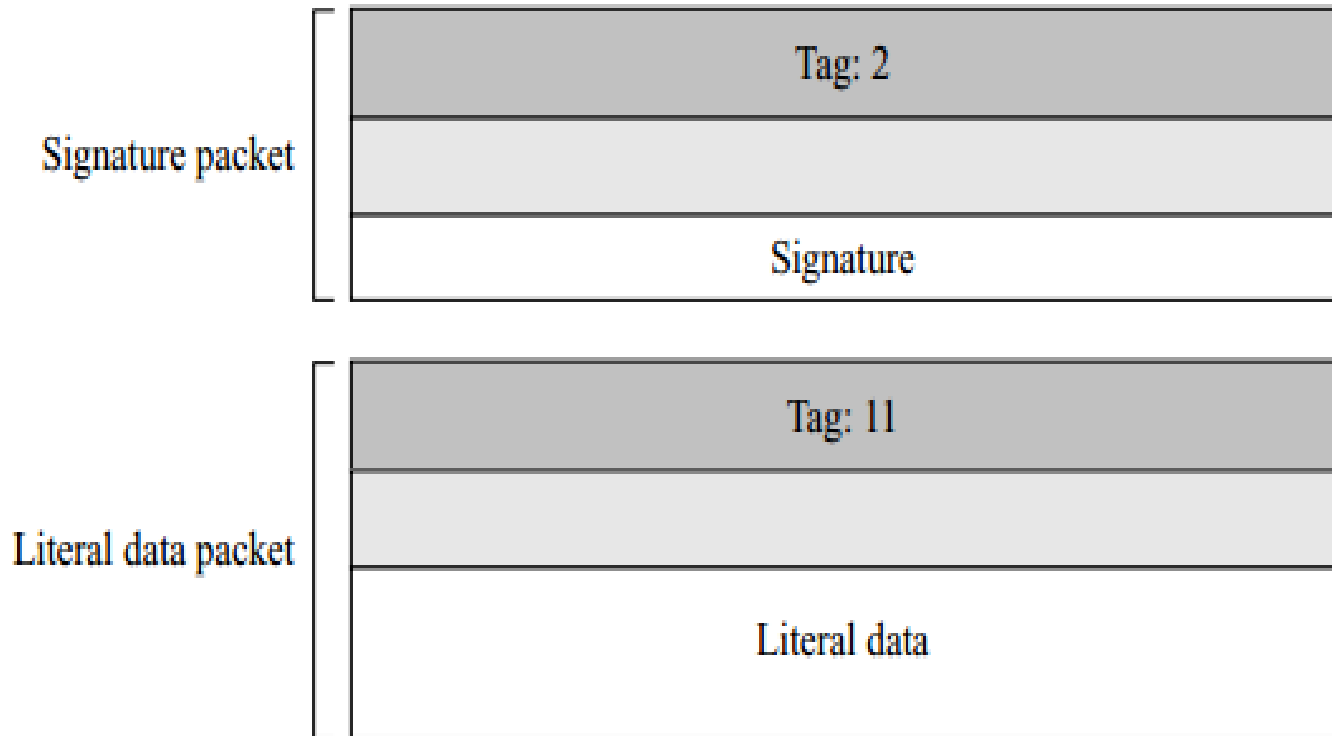
- An encrypted message can be a sequence of two packets
 - a session-key packet
 - symmetrically encrypted packet (a nested packet)

Encrypted Message



Signed Message

- A signed message can be the combination of a signature packet and a literal packet



Certificate Message

- It is the combination of a user ID packet and a public-key packet
- The signature is then calculated on the concatenation of the key and user ID.

Certificate Message

